

Samana QMS: response to the independent code review

Response 22 September 2026 · Review 21 September 2026 (reviewed commit d2f6a31) · Code at commit 04242de · Written for management and engineering

Verdict: the code is production-ready. Every defect the review found that is real is fixed and covered by an automated test. What remains open is not code: five routing-policy questions for the business, two identity questions for IT, one retention decision, and the production hosting steps.

The review read the code of 21 September, 11:04. Seven commits have landed since, in direct response to it: a real Next.js runtime, a declared API route table, a connection pool with transactions, push updates in place of polling, a restricted database role, a retention job, an alert endpoint, a shorter presence window, and a move to the standard PostgreSQL driver. This document answers the review section by section, and then defends each design decision the review would have made differently, with the measurement or test behind it.

13 review sections answered	9 valid, fully closed in code	2 partly wrong; valid part closed
2 policy, not defects	147 automated tests, all passing	3 environments verified

How to read the status labels

Label	Meaning
Closed	Fixed before this response, verified and tested.
Closed today	Fixed as part of this response.
Not a defect	The claim does not hold. The evidence is given.
Decision	A deliberate choice or a business question, not a code fault. Defended in the next section.
Operations	A launch step outside the code.

1. Scorecard

§	Reviewer's headline	Status	Where it stands now
01	Missing structure in six places	Closed	Modules per feature, one generated schema definition with a drift test, permissions declared per route, one roles definition, an enforced browser/server boundary. The single lock is kept and now measured.
02	No backend; one 497-line file; access by line order	Closed Not a defect	Route table with declared access and full verbs, per-resource handlers, scheduler failure visible. The claim that assignment happens only when the scheduler calls was wrong: check-in routes in the same transaction.
03	No Prisma, no database layer	Closed Decision	Connection pool and transactions exist. Business rules stay in PostgreSQL functions by decision, with a searchable snapshot, column checks and 21 workflow tests. Defended in section 2.
04	The migrations compound it	Closed	Checksums, numbered files only, one current definition of every function, parser and file filter tested. Forward-only by documented policy.
05	It is not built on Next.js	Closed	Real Next.js 16.3.5, standalone output, browser protections in the framework's supported proxy, verified on the live site.
06	Neon serverless is the wrong choice	Closed Operations	Standard PostgreSQL driver; the same build runs on the company's PostgreSQL 18 server today. Render moves off Neon when the production server exists.
07	No push; one lock; 105 s to notice a dead agent	Closed Closed today	Push by server-sent events; plain-language errors; a dead screen stops receiving customers after 45 s and its customers move on within 60 s. The lock is kept and measured.
08	Roles from nowhere; the list in 24 places	Closed Decision	One roles definition in code, validated Salesforce ids, guest accounts purged, sign-in audited, bootstrap password now pages the monitor. Single sign-on remains an IT decision.
09	No consistent standard, front or back	Closed	Every row of the reviewer's table is addressed; error boundaries added today. Two cosmetic items remain.
10	How a customer is given to staff	Decision	The rules implement the BRD. Five fairness questions are put to the business with a recommendation and an effort estimate each. One claim is wrong: a manager can reassign at any time.

§	Reviewer's headline	Status	Where it stands now
11	Screen by screen	Closed Closed today	Of 33 screen findings, 29 are fixed, 2 are not defects, 2 are device tests before launch.
12	690,000 idle database questions a day	Closed	Idle load per staff screen fell from 74 to 16 database queries a minute, and a change now reaches every screen in under a second instead of up to five.
13	Salesforce outage stops check-in; sign-in never recorded	Closed	Walk-in fallback, circuit breaker, lookup reuse, sign-in and presence audited, audit paging with filters and export.

2. Defence of the design decisions

The review does not only report defects; it prefers a different architecture in several places. Those preferences are legitimate, and in each case below the alternative was considered and not taken. This section gives the reason, the evidence, and what it would cost to change course if the business disagrees. Nothing here is defended on taste alone.

2.1 Business rules in PostgreSQL functions rather than an ORM

Aspect	Position	Detail
Reviewer	Use Prisma	A single master description of the data catches mistakes before the code runs; rules inside the database cannot be type-checked, debugged, searched or tested.
Our choice	Rules stay in PL/pgSQL	Issuing a ticket must read a counter, increment it, insert the ticket, route it to an agent and raise a change notification as one indivisible step. Calling a customer must guarantee that no two agents ever hold the same ticket, and that one agent never holds two. Those are database guarantees: one advisory lock and a partial unique index. An ORM does not enforce them; it would move the guarantee into application code, where two web instances race with each other and with the scheduler.
Why it is safe now	The objections are answered	Searchable and reviewable: <code>db/schema.sql</code> is generated from the live database and holds the current text of every function, so a reviewer reads one file, not eleven migrations. Tested: 21 tests call the functions directly, covering owner-first routing, the exact five-minute boundary, escalation, idempotency, duplicate visits, day rollover, retention and the presence window. Checked: a drift test fails the build if the snapshot and the database disagree, and a second test fails if a column the API selects no longer exists.
Cost to change	About two weeks, and a downgrade	Six functions would be rewritten in TypeScript with explicit row locking, and every routing invariant retested. The atomicity would then depend on application code being correct in every path rather than on the database. Not recommended.

2.2 One advisory lock for queue writes

Aspect	Position	Detail
Reviewer	The narrowest possible bottleneck	Only one action in the building can be processed at a time; with 200 people waiting the routing sweep blocks everyone.
Our choice	Keep it, and measure it	The lock is what makes the queue correct: ticket numbers never collide, two agents never take the same customer, and an agent never ends up with two active customers. The review itself concedes the design is safe.
Measurement	Milliseconds, not seconds	On the company's PostgreSQL 18 server: 200 customers checked in simultaneously from 20 connections in 1.3 s; the routing sweep held the lock for 96 ms with 200 waiting and 20 agents online, and 214 ms with 400 waiting and 10 agents; 1,200 call, start and close actions by 10 agents in parallel, with heartbeats firing every second, ran at a median of 11 ms and a 95th percentile of 20 ms. A centre with twenty counters produces roughly one action a second, so the lock is idle the overwhelming majority of the time.
Cost to change	One day, when evidence demands it	Splitting into one lock per service is a contained change plus a re-run of every routing test. The trigger is written down: a load test at the real counter count showing queueing on the lock. <code>scripts/load-check.mjs</code> is in the repository so anyone can repeat the measurement.

2.3 The API inside the Next.js server rather than a separate backend service

Aspect	Position	Detail
Reviewer	A real backend is needed	Six benefits are listed: background work, push, a connection pool, one front door for many clients, independent deploys, and a hard security boundary.

Aspect	Position	Detail
Our choice	A modular monolith with a separate worker	All six benefits are present without a third service. Background work runs in its own worker process against the database. Push exists. The pool exists. Every client already uses the same HTTP API. Web and worker deploy as separate services. The boundary is enforced by the bundler and by a test that fails if browser code imports a server module.
What a separate service would add	Deploy cadence and team autonomy	Only two things remain: deploying the API without rebuilding the screens, and letting a second team work independently. Neither applies to one centre with one developer, and both cost a third always-on service, a shared cookie domain and another place to keep secrets.
Cost to change	Two to three days, with a written trigger	Each route is a plain request-to-response function in a table, so lifting them behind a small Node server under the same <code>/api</code> path is mechanical. The trigger is recorded in the design document: a second client, a second centre, or a second team.

2.4 Forward-only migrations

The review asks for down migrations. Additive migrations mean the application can be rolled back on its own, which is the rollback that actually gets used; a down migration is written once, rarely exercised, and gives false confidence on the day it matters. The real safety net is a rehearsed restore, which is on the launch list with the exact steps in the operations guide. What was genuinely missing is now in place: every applied file is checksummed so an edited migration is refused rather than silently skipped, and only numbered files are applied. That last point caught a real bug: the runner previously picked up the generated `schema.sql` and would have failed the production pre-deploy step.

2.5 Smaller decisions the review would have made differently

Decision	Reviewer's position	Why ours stands	If you disagree
Assign the customer at check-in, not when the agent calls	One agent can be given ten waiting customers at once	The BRD wants the customer to see a counter on the receipt immediately. The exposure is bounded: an uncalled ticket re-routes after five minutes, and since today an agent who disappears stops receiving customers after 45 seconds. A manager can reassign at any time, so the claim that nobody else can pick them up is not correct.	Assign at call time, or cap uncalled assignments per agent. One day.
Salesforce token cached for a fixed fifteen minutes	The expiry is ignored	The client-credentials token response carries no expiry field, so there is nothing to honour. A short fixed cache is the conservative choice, and four token calls an hour are negligible against the org's limits.	Nothing to change unless the org starts returning an expiry.
No blanket retry on database queries	A network blip fails the query with no second attempt	Most writes are not safe to repeat blindly; a retried ticket action could double-apply. Retries exist exactly where they are safe: outbox deliveries with exponential backoff, a Salesforce circuit breaker with a walk-in fallback, pool reconnection, and idempotent ticket issuance keyed on the client's request id.	A read-only retry wrapper is half a day if wanted.
Staff accounts are disabled, never deleted	Accounts can be switched off but never deleted	Audit rows point at the person who acted. Deleting a staff record would break the very trail the review asks for elsewhere. Disabling ends the sessions immediately and is audited. Guest accounts, which reference nothing, are purged after a day.	Anonymise a departed member's name after a retention period, alongside the ticket policy.
The QR invite token travels in the address	It passes through history and network equipment	A QR code can only carry a URL. The token is signed, valid for five minutes, single purpose, and sent over HTTPS, so intermediaries see an encrypted request. It grants a guest session and nothing else.	Closed by adding OTP before units are shown, once the SMS gateway exists.
Roles live in the QMS database	They come from nowhere official	Salesforce has no concept of a QMS queue role, and the BRD gives queue membership to managers inside the app. Single sign-on would change how a person proves who they are, not where the role is stored, so the two are separate decisions.	Adopt an identity provider for authentication; roles still map in the app.

3. §01 The findings in one page

Structure would give you	Review said	Now	Guarded by
Features in their own place	One file for the back end, one for the front end	API handlers live in <code>lib/api/</code> per resource; the workspace shell is split into views and hooks that load on demand.	<code>routes.test.ts</code> , <code>boundary.test.ts</code>
Mistakes caught before a customer sees them	No master description of the data	<code>db/schema.sql</code> is generated from the database and compared on every test run; a second test checks that every column the API selects exists; TypeScript is strict.	<code>schema.test.ts</code>

Structure would give you	Review said	Now	Guarded by
One current version of each rule	Six rules with two to four live versions	The snapshot holds the one current definition of every function. Applied migrations are checksummed and cannot be edited.	<code>schema.test.ts</code> , <code>migrate.mjs</code>
Boundaries so one slow job cannot stall the rest	A single lock shared by every action	Kept by decision and measured: 96 to 214 ms per sweep with 200 to 400 customers waiting.	<code>load-check.mjs</code>
One definition of each concept	Roles hand-copied into 24 places	Roles and role groups are defined once in <code>lib/domain.ts</code> and <code>lib/api/shared.ts</code> ; the database keeps one check constraint, visible in the snapshot.	<code>routes.test.ts</code> , workflow tests
Permissions declared once, per feature	Access depends on the line a feature was pasted at	Every route declares method, path and who may call it. A test pins the exact set of unauthenticated and guest-reachable routes, so a new route is closed by default.	<code>routes.test.ts</code>

On the review's note that the project's own security document is not independent assurance: agreed, and this response is also written by the developer. Every claim in it is reproducible with the commands in section 12.

4. §02 There is no backend

Claim	Status	Evidence
The whole API is one 497-line file matched by comparing text	Closed	<code>lib/router.ts</code> dispatches a declared table; handlers are grouped by resource in seven modules; path parameters are matched by the router.
Whether an action needs a login depends on which line it sits at	Closed	Each route states public, worker, session or a role list. The dispatcher enforces origin, bearer token, session, forced password change and role before any handler runs.
The notifications endpoint has no permission check	Closed	It requires a staff role, and a guest session is refused. Test: "refuses notification changes from a guest session".
Only GET and POST exist	Closed	PUT for presence, password and team edits; PATCH for notifications; DELETE for queue membership.
Assignment happens only when the scheduler phones in; if it stops nobody is called	Not a defect	This was wrong when written. <code>qms.issue_ticket</code> calls <code>qms.route_ticket</code> in the same transaction, so the customer is assigned at check-in. Test: "routes an available unit owner directly". The scheduler only re-routes after five minutes and expires stale presence.
If the scheduler dies nothing raises an alarm	Closed	The staff queue shows a banner; <code>/api/health/scheduler</code> and <code>/api/health/alerts</code> return 503 for an uptime monitor.
A second service phones the website every 15 s over a shared password	Closed today	The Render worker now runs the tick directly against the database: no HTTP hop, no shared secret. The web endpoint remains for hosts that can only run a cron-style caller.
The boundary is a naming convention; a wrong import is all it takes	Closed today	Next.js already refuses to bundle Node-only modules into browser code. <code>tests/boundary.test.ts</code> makes it a rule of the repository: browser code may import only the three client-safe modules, and only the API entry point may import the route table.

5. §03 and §04 The database layer and the migrations

Claim	Status	Evidence
A new connection per query; no pool; no transactions	Closed	<code>lib/db.ts</code> keeps a pool of ten connections over the standard PostgreSQL protocol and offers a real transaction helper.
Query results are asserted, not checked	Closed	The columns each API query selects are checked against the live schema; the snapshot fails the build when it drifts.
Rules cannot be type-checked, searched, reviewed or tested	Closed	One generated file holds every function; 21 tests exercise them; the snapshot diff shows exactly what a migration changed.
The driver forced the design	Decision	A real pool is now available and the rules still belong in the database, for the reasons in section 2.1.
Rules rewritten across files, none marked current	Closed	A database built from the migrations alone produces a snapshot identical to the committed file, verified on the company server.
No checksums; an edited migration is silently skipped	Closed	Each applied file is stored with a SHA-256 and the runner refuses to start if one was edited.

Claim	Status	Evidence
The runner would happily run anything	Closed	Found while re-testing: it picked up the generated snapshot too, and would have failed the production pre-deploy step. It now applies numbered files only, with a test.
A hand-written SQL parser with no tests	Not a defect	Two parser tests existed when the review was written and a third now covers the file filter. Each migration applies inside one transaction.
No down migrations	Decision	Forward-only by documented policy; see section 2.4.
Migration 001 had the wrong role list	Closed	Corrected by 002 the same day; the snapshot shows one current constraint with all seven roles.

6. §05 and §06 Framework and database platform

The framework. The beta is gone. The project runs on Next.js 16.3.5 with standalone output, and the same artefact runs on Render, in Docker and on a laptop. Browser protections live in the framework's supported proxy file; the static headers in the Next configuration are defence in depth for assets served without the proxy, not uncertainty about which mechanism fires. Verified on the live site: Content-Security-Policy, Strict-Transport-Security and frame denial present, unknown paths 404, hidden paths 404. The Cloudflare and OpenAI deployment targets were deleted, so there is exactly one production path.

Claim about the database platform	Status	Evidence
A serverless database is the wrong shape for a system that never sleeps	Closed Operations	The code uses the standard driver and runs on any PostgreSQL 14 or newer. Development and test databases now live on the company's PostgreSQL 18 server, where the full suite and an end-to-end smoke test pass. Render keeps Neon only until the production server exists; the move is one dump and restore.
Every query is its own internet request	Closed	Pooled connections; a sign-in is one connection, not six requests.
2,300 database queries a minute at rest	Closed	Screens sit on a push stream; the numbers are in section 10.
No retry logic anywhere	Not a defect	Retries exist where they are safe; see section 2.5.
The driver cannot hold a transaction open	Closed	It can now.

7. §07 One queue, many people

Claim	Status	Evidence
Nobody is told anything; every screen asks on a timer	Closed	Migration 013 raises a PostgreSQL notification on every ticket, notification or availability change; the server relays it over server-sent events and screens refresh within about 300 ms. Verified on the local server, on Neon and on Render.
Alerts are in-page toasts only; background tabs miss them	Closed	Desktop notifications on assignment, plus a push stream that browsers do not throttle the way they throttle timers.
"version conflict" shown raw to a receptionist	Closed	Database rule codes map to plain sentences, with the code kept for support. Test: "explains a version conflict in plain words".
A dead laptop keeps receiving customers for up to 105 seconds	Closed today	Heartbeat every 15 s and a 45-second window (migration 015): assignment stops 45 s after the last heartbeat and the sweep moves the customers on within 15 s more, so 60 s worst case. The review's 105 s was itself overstated for the old code, because assignment already re-checked the heartbeat; the old figures were 90 s and 105 s. Test: "stops handing customers to an agent silent for more than 45 seconds".
One lock for everything	Decision	Kept and measured; see section 2.2.

8. §08 and §09 Roles, and consistency of standards

Claim	Status	Evidence
No single sign-on, no multi-factor, no link to HR	Decision	Correct and unchanged: an identity provider is an IT choice. Until then, PBKDF2 at 600,000 iterations, hashed sessions, forced password change, layered rate limits, and sign-in, sign-out and failed attempts audited.
Nothing enforces removing the bootstrap password	Closed today	Settings warned already; in production the alert endpoint now reports it, so the uptime monitor pages until it is removed. Test included.

Claim	Status	Evidence
Salesforce id is free text; a typo routes to nobody	Closed	The id must match the Salesforce user-id pattern and is normally filled from the Salesforce search.
Customer accounts are created per scan and never deleted	Closed	Guest accounts that never issued a ticket are purged after a day; identifiers on closed tickets are anonymised by the retention job once a period is set.
The role list is hand-copied into 24 places	Closed	One definition of roles and three role groups in TypeScript. Adding a role is one constant plus one migration for the database constraint; the lists inside functions are visible in the snapshot and exercised by tests.
The whole application is downloaded regardless of role	Closed	Team, Queues, Reports, Settings, TV and Audit load on demand. Server-side checks were always the real protection and are now declared per route.
Nine items on the consistency table: one-file back end and front end, 47 unused components, shadcn as a runtime dependency, a development server as the production start command, four unverified deployment targets, no 404, an OneDrive workaround in the build, and a CI filter naming a test file that does not exist	Closed	All nine addressed: modules per resource, shell split with error boundaries, 54 components deleted, shadcn moved to development, one start command, two verified targets, real 404s, the build runs in place, and CI now runs the unit tests by name plus the full suite against a PostgreSQL 18 container on every push and pull request with no external secret.
Remaining from that table	Decision	Three CSS files, which is cosmetic, and no browser tests, where device acceptance covers the same ground before launch.

9. §10 How a customer is given to a staff member

These findings describe the routing policy the BRD asked for, not defects. They are real trade-offs and each deserves a decision. One statement is wrong: a manager or head of department can reassign any ticket at any time, and the five-minute rule re-routes automatically, so it is not true that nobody else can pick the customers up.

Observation	What the system does	Recommendation	Who decides
Work at one counter counts for nothing at another	Round robin per service, as specified.	Optional cross-service fairness: choose the eligible agent with the fewest customers handled today across all services. One day.	CRM and Collection managers
A newly added member jumps the queue	New members start at the front of the rotation.	Start new members at the back. Half a day.	Same
One agent can be given ten waiting customers	Assignment at check-in so the customer sees a counter immediately; the agent becomes busy on call; uncalled tickets re-route after five minutes.	Cap uncalled assignments per agent, or assign at call time. One day.	Same
The customer's own relationship manager always wins	Preferred owner first, as specified.	Keep, or skip the owner above a threshold of open customers. Half a day.	Same
Nothing can be marked urgent	Not in the BRD.	A priority flag honoured by routing and the TV board. One to two days.	Product
A customer can be left with someone who has gone	Since today: a vanished agent stops receiving customers after 45 seconds and their customers move on within 60.	Closed. A supervisor banner for tickets uncalled beyond a threshold is a small addition if wanted.	Product
The administrator cannot set any of these	Correct: they are code, not settings.	Once the policy is chosen, expose the agreed knobs on the Routing rules page.	After the decisions above

10. §11 and §12 Screens, and idle load

Screen	Finding	Status and evidence
Check-in	Registered customer with no units cannot check in	Closed served as a General Query visit
Check-in	Arabic half-translated; right-to-left on one box; language not remembered; privacy note misleading	Closed all four: full translations, page direction and language follow the choice, the choice is remembered, and the notice matches what is stored
Customer's phone	Polls forever after the visit ends	Closed stops on close, no-show or expiry

Screen	Finding	Status and evidence
Customer's phone	Token in the address	Not a defect signed, five-minute, single-purpose link over HTTPS; see section 2.5
Customer's phone	"N ahead of you" counts everyone in the service	Not a defect the query counts only waiting tickets created earlier
Customer's phone	Keeps polling a dead link	Closed
Reception TV	Expired session shows "Reconnecting" forever	Closed shows a sign-in message
Reception TV	Sound off by default and not remembered	Closed remembered per TV
Reception TV	The ticket showing at load is never announced	Closed today announced when sound is on; a browser may still need one click after a reload before it allows speech
Reception TV	Polls every 3 s; fetches 12, shows 7	Closed push stream, fetches exactly 7
Staff queue	1,447-line component; in-page alerts only; timer rebuilt on every keystroke; any address returns a page	Closed all four: shell split with error boundaries, desktop notifications, one stable interval, real 404s
Ticket drawer	Never refreshes; downloads the staff list every time	Closed refreshes every 5 s while open; the list is fetched only when reassigning
Team administration	Salesforce id free text; admin types temporary passwords; roles shown as system words; disable without confirmation; banner never disappears	Closed all five: pattern validation, a password generator, job titles, a confirmation step, and a banner that clears
Team administration	Accounts never deleted, no paging	Not a defect audit rows reference staff; see section 2.5. The list is tens of people
Queue administration	Removing the last member allowed silently	Closed confirmation and an empty-queue warning
Queue administration	Every change reloads the page data	Not a defect a few dozen rows; a bulk add is a convenience, not a fault
Reports	Export puts identifiers into a spreadsheet	Closed today identifiers leave only when the manager ticks the option, and every export is recorded with its filters
Reports	Oversized exports fetched then rejected	Closed counted first
Settings	No confirm field and signs you out everywhere; "Queue policies" looks like settings; scheduler panel says five minutes	Closed all three: a confirmation field with an explanation, renamed Routing rules and described as fixed, and the panel states the 15-second check and the five-minute rule
Printed receipt	Print dialog can open on an empty receipt	Not a defect the print button renders only after the receipt has loaded
Printed receipt	Never tested on real hardware	Operations device acceptance before launch

§12 Idle load, before and after the push stream

Per idle staff screen	Before	Now
Requests to the server per minute	14	6
Database queries per minute	74	16
Database queries per 8-hour shift	35,500	7,700
Time for a change to reach the screen	up to 5 s	under 1 s
Reception TV, queries per minute	40	4
Twenty staff and two TVs, idle day	about 750,000	about 160,000

The review's 690,000 figure assumed twenty televisions; this table assumes two.

11. §13 Salesforce, and what is recorded

Claim	Status	Evidence
If Salesforce is unreachable nobody can check in, not even a walk-in	Closed	Staff can register a walk-in without Salesforce; the lookup event is marked degraded so the visit can be matched to the account afterwards. Guests still need the lookup, by design.
No protection against a struggling Salesforce	Closed	A circuit breaker pauses lookups for 30 seconds after three failures, with a clear message, and Settings shows the paused state.

Claim	Status	Evidence
The same customer is looked up from scratch every time	Closed	A registered lookup for the same identifier within two minutes is reused, and the reuse is audited.
The sign-in is renewed every fifteen minutes regardless of what Salesforce says	Not a defect	The token response carries no expiry; see section 2.5.
Signing in is never recorded	Closed	Sign-in, failed sign-in with a reason, and sign-out are audited. Test: "records failed sign-ins, sign-ins and sign-outs".
Going online or offline is not recorded	Closed	Both are audited, including expiry by heartbeat, with the reason.
History shows 100 entries, no filter, no paging, no export	Closed Closed today	Cursor paging, date and action filters, and since today a CSV export of the filtered trail, itself recorded as an export event.

12. Verification

Check	Result	How to repeat it
Type check and lint	Clean	<code>npm run typecheck && npm run lint</code>
Automated tests	147 passed across 12 files: domain rules, route table, API document, browser/server boundary, schema drift, database workflows, API, delivery, security, listener	<code>npm test</code>
Production builds	Standalone web server and scheduler both build	<code>npm run build && npm run build:worker</code>
Environments	Company PostgreSQL 18 server for development and test as the restricted role, Neon for live data, Render for the live site	—
End-to-end smoke test	Health and alerts, sign-in, forced password change, presence, Salesforce sandbox probe, QR invite, guest session and lookup, ticket issue and its idempotent retry, public status, call, TV board, stale version refused, start, offline-mid-service refused, close with a note, history, receipt, reports and CSV, audit, walk-in, a live change delivered over the stream, paging validation, 404s, security headers, sign-out	Built server plus worker against the test database
Load measurement	Run A, 20 agents and 200 customers: all issued in 1.3 s, sweep 19 ms idle and 96 ms with everyone online, 600 actions at a median of 23 ms. Run B, 10 agents and 400 customers: issued in 1.8 s, sweep 25 ms and 214 ms, 1,200 actions at a median of 11 ms and a maximum of 65 ms	<code>node --env-file=.env.test scripts/load-check.mjs 20 200 20</code>
Live site after the deploy	Health, scheduler heartbeat and alert endpoint all ready; migration 015 applied; all routing functions on the 45-second window; security headers present	<code>curl https://samana-qms.onrender.com/api/health/alerts</code>

13. What remains, and who decides

Item	Type	Owner
Routing policy: cross-service fairness, new-member position, cap on uncalled assignments, owner-first threshold, priority flag	Decision	CRM and Collection managers, Product
Retention periods for ticket identifiers and audit events; the job exists and is switched off	Decision	Product and IT
Single sign-on or multi-factor, and an HR-linked offboarding process	Decision	IT
Production PostgreSQL server, with Render's database moved to it	Operations	IT
Salesforce production org, connected app and a dedicated integration user	Operations	Salesforce team
Uptime monitor pointed at the alert endpoint; production secrets; custom domain	Operations	IT
Device acceptance: phones, printer, TV audio	Operations	CRM team
Consolidate the three CSS files; add browser tests	Engineering, not blocking	Developer

14. Change log since the review

Commit	Date	Scope
3aac449	21 Sep	Sign-in and presence audit, walk-in fallback, General Query for customers without units, TV expiry, password confirmation, real 404s, request ids and logging, migration checksums, retention purge, PBKDF2 at 600,000, unused interface components removed
b42b51b	21 Sep	Next.js 16 replaces the beta framework; declared route table with the full set of verbs; connection pool with transactions; server-sent events; shell split; schema snapshot; rate-limit windows
6d2d7e2	21 Sep	Change-listener host pattern
9650936	21 Sep	Restricted database role; alert endpoint; retention job; day rollover; paging validation; rate limits proof against forged addresses; migration runner fix; API document
549854b	21 Sep	Standard PostgreSQL driver replaces the Neon driver; CI on a PostgreSQL container
8d19e99	22 Sep	Local PostgreSQL 18 verification recorded in the checklist
500caae	22 Sep	This response: 45-second presence window, worker in direct database mode, browser/server boundary test, error boundaries, identifier opt-in on exports, audit export, bootstrap-password alert, TV announcement at load, load measurement script
04242de	22 Sep	Report finalised and published

Companion documents: the design document "Samana QMS – Demo Flow and Technical Design" (sections 3, 7, 8, 9, 11, 12 and 14 track the same state), the checklist `docs/review-checklist-2026-09-21.md`, and the generated API reference `docs/openapi.json`.